

Introduction:

Applied Cyber Threat Analysis – Access Controls Lab

- This lab was conducted within the Virginia Cyber Range Environment.
 - Report based off assignment assigned by George Mason University - Department of Information Sciences and Technology College of Engineering and Computing
 - Cheche Agada. (2024). Access Control Lab IT-462: Applied Cyber Threat Analysis, George Mason University
-

Passwords are the most popular access control methods in use today. In this lab we will look at attacks against passwords and how such can be prevented.

Objective:

Demonstrate the process of password cracking as a way of bypassing an access control method.

Task 1 – Testing Password Strength

- In your Windows VM, open a web browser and navigate to the following links.
 - <https://www.security.org/how-secure-is-my-password/>
 - <https://www.uic.edu/apps/strong-password/>
 - <https://passwordmeter.com/>
- Using the web pages in the links above, test the strengths of the passwords provided in the table below and complete the table.

S/N	Password	Complexity	Score	Time Required to Crack
1	1234	Very weak	4%	instantly
2	Password	Very weak	8%	instantly
3	Password1	good	54%	3 days
4	MyPassword	weak	36%	1 month
5	MyPassword@	Strong	68%	96 years
6	SuperDuperPass1?	Very strong	100%	2 trillion years

7	QuestMaster83!	Very Strong	100%	200 million years
8	PasswordPassword 2@	Very strong	100%	7 quadrillion years
9	PassworddorwssaP 3#	Very strong	100%	7 quadrillion years
10	SpongeBob^2rdPa nts	Very strong	100%	7 quadrillion years

Lab Exercise 1**Task 2 – Cracking Passworded Files using John the Ripper**

- Download the zipped folder (Passworded Files.zip) from Blackboard.
- Unzip the folder, it contains the 5 files listed in the table below.
- The files are locked with a password, and each contain a flag (hidden message/graphic).
- Search for the appropriate **John the Ripper** commands on Google, etc.
- Run the appropriate command against each file to crack the password.
- Obtain the password as well as the flag in each file.
- Fill in the missing information in the table below.

NOTE:

- John the Ripper is a password cracking application. It is pre-installed in Kali Linux.
- The Applied Cyber Threat Analysis 2 environment in the VCR contains a Kali Linux VM (Cyber Basics (2023.10)).
- Ensure you open the files in the appropriate operating environment, i.e., you cannot open a Windows file in Linux, and you cannot open a Word file if MS Word is not installed on your system.
- You may choose to send the flag/file by email or Blackboard message to your regular Windows/Mac environment after obtaining and entering the password in Kali, if you are unable to open/view the file in the Cyber Range environment.
- If you get an error message: (i.e. **Crash recovery file is locked: /home/kali/.john/john.rec**), navigate to the file path specified in the error message (i.e. **/home/kali/.john/john.rec**), and delete the file (i.e. **john.rec**)

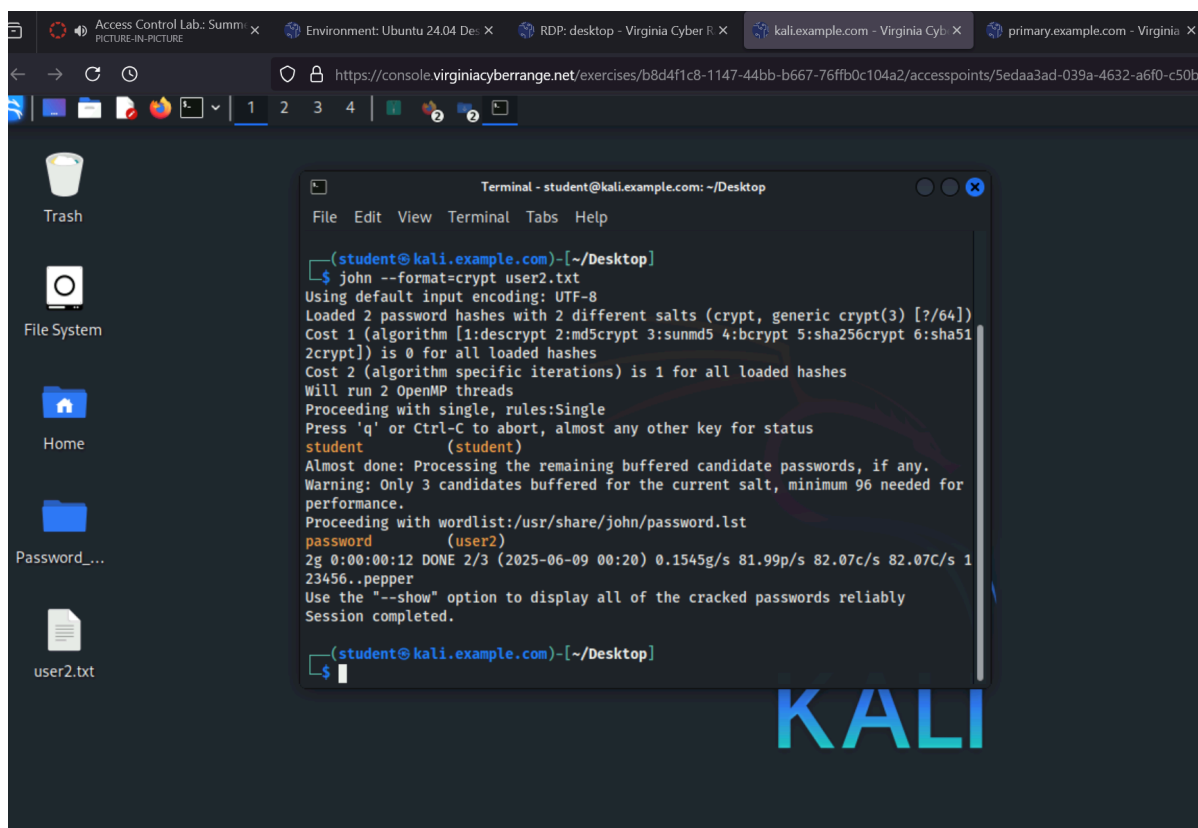
S/N		Password	Flag	Time to crack (approx.)
1	File.zip	password1	Congrats!!! You captured the flag	1 second
2	Unknown.rar	1234	Capitol.jpg (image of the capitol)	20 seconds
3	newdocx.docx	Password	ejfhigsfbkjsfns	1 min
4	CrackMe.pdf	qwerty	A very weak password	20 seconds
5	MySheet.xlsx	iloveyou	Flag = Great, you cracked it!	30 seconds

Task 3 – Extracting User Account Password from an Ubuntu Password File

- In your Ubuntu VM, open up a terminal and create a user account and password using the following commands:
 - `sudo su` [provide superuser password if requested]
 - `useradd -r {username}` i.e. `useradd -r user2`
 - `passwd user2` [choose a password for the account, make sure it is a weak password (i.e., password, test, student, etc.)]
 - Make sure you still have root privileges (i.e., `#`)
 - Confirm that the user you created is in the system (`cat /etc/shadow`). It should be at the bottom of the page.
- Copy the username and hash of the password for the user account you just created into a text file (i.e., `user.txt`).
user2:\$y\$j9T\$MMWYQDY/1FUiM1eqYKMG01\$vbIGgrXR4ELETEA.R7COrtn/Cz5h4zeOU p3QY6Cblu6:20248::::::
- Copy/transfer the file out of the Ubuntu VM into the Kali VM.

Task 4 – Cracking User Account Password using John the Ripper

- Open up a terminal in the Kali VM, navigate to the location holding the file (i.e., `user.txt`) copied from the Ubuntu VM, containing the username and hash of the password.
- Use the following 'John the Ripper' command to search for the password of the user account created on the Ubuntu VM:
 - `john --format=crypt [name of password file]` (i.e., `john --format=crypt user.txt`)
- If the password is successfully recovered, it will be displayed in the terminal.



NOTE:

- 'crypt' is the format for storing password hashes in the Linux OS.
- It will take a while to recover the password if you choose a complex/strong password, so use a simple password (i.e., password, test, student, etc).
- There is a double dash (--) before the word 'format' in the command (i.e., `john --format=crypt user.txt`).

Lab Exercise 2

- In what situation will task 2 and task 4 be used by a security professional.
Cracking passwords is useful for cybersecurity professionals because it helps gauge the weakness of a client's password hygiene. This can be used to facilitate a training scenario to help the employees of the client to strengthen their password practices.
- In what situation will task 2 and task 4 be used by a bad actor?
Bad actors can use these tools to steal passwords to systems that hold sensitive data.

How can attacks against passwords be prevented?

Having strong passwords that are too complex for these password crackers to break.